Information Security Policy

Owner: Meera Nair, CISO | Version 5.1 | Effective 15 January 2026 | Next review 14 January 2027

Document control

Field	Value
Document ID	KB-POL-001
Classification	Internal
Owner	Meera Nair, CISO
Approved by	MD & CEO (fictional)
Applies to	All Nimbus employees, contractors and engagements
Related documents	KB-POL-003, KB-POL-004, KB-POL-005, ISMS Statement of Applicability v3.1

1. Purpose and scope

This policy sets the information security requirements for Nimbus and for the services Nimbus delivers to clients from its Bengaluru and Pune delivery centres and at client sites. It is the top-level policy of the ISMS certified to ISO/IEC 27001:2022 (certificate SYN-ISMS-2023-0412, valid until 10 November 2026).

2. Roles

- The CISO owns the ISMS and reports to the MD & CEO.
- Delivery managers are accountable for security controls in their engagements.
- All employees complete security awareness training every year.

3. Access control

Access is granted on least privilege and reviewed every quarter. Privileged access to client systems is only through the client's PAM solution where available, otherwise through the Nimbus PAM. Multi-factor authentication is mandatory for remote access.

4. Patch and vulnerability management

Critical security patches are applied within 14 days of release, and high-severity patches within 30 days, unless the client contract sets a shorter period. Where a contract requires a shorter period, the contract prevails and the engagement's patch procedure must state it.

Critical vulnerabilities found in VAPT are closed within 15 days, high within 30 days, unless the contract sets shorter periods.

5. Incident management and reporting

Cyber security incidents covered by the CERT-In Directions of 28 April 2022 are reported to CERT-In within 6 hours of being noticed, and to the affected client within the time set in the contract or, if none, within 2 hours.

Logs of ICT systems are retained securely in India for a rolling 180 days.

6. Data residency

Client data, backups and logs are kept in India unless the client gives written approval otherwise. Monitoring tools are configured to disable telemetry that would send data outside India.

7. Supplier security

Suppliers with access to client data sign NDAs and security clauses; critical suppliers are assessed every year.

8. Exceptions

Exceptions are approved by the CISO, recorded in the risk register with an expiry date, and reviewed monthly.

9. Asset management

Information assets are inventoried in the CMDB with an owner and a classification. Client assets are managed under the client's asset register.

10. Cryptography

TLS 1.2 or higher for data in transit; AES-256 for data at rest under Nimbus control; keys in an HSM or the client's key management system.

11. Logging and monitoring

Security-relevant events from Nimbus systems are sent to the Nimbus SIEM; on client sites, Nimbus uses the client's SIEM and does not copy logs out without approval.

12. Secure operations at client sites

- Privileged sessions recorded through PAM
- No personal devices in data halls
- Change records required for all production changes
- Background verification before deployment

Compliance and monitoring

Compliance with this policy is checked in internal audits twice a year and in certification audits. Breaches are handled under the disciplinary procedure. Exceptions follow the exception process of the owning function and are recorded with an expiry date.

Revision history

Version	Date	Change
4.0	2023-11-01	Aligned to ISO/IEC 27001:2022 Annex A
5.0	2024-12-10	Added CERT-In 6-hour reporting and log retention
5.1	2026-01-15	Data residency and telemetry controls